PHISHING EMAIL ANALYSIS REPORT

Decathlon Fake Voucher Phishing Campaign | Forensic Case Study

Prepared By	Dhruva khare
Project Title	Phishing Email Forensic Analysis — Internship Assignment
Email Sample Date	Friday, 4 August 2023
Tools Used	Microsoft Outlook · Email Header Analyser · HTML Source Inspector
Analysis Coverage	Email Forensics · Social Engineering · Web Application Security
Report Status	FINAL — For Internship Submission
Classification	CONFIDENTIAL — Academic Use Only

Produced as part of a supervised Cybersecurity Internship Programme | Not for public distribution

1 Executive Summary

This report presents a comprehensive forensic analysis of a phishing email intercepted on **Friday, 4 August 2023**. The email impersonated the global sporting-goods retailer **Decathlon**, falsely promising a **€1,000 gift voucher** to lure German-speaking recipients into clicking a malicious link. The email was captured in a controlled *phishing-pot* mailbox for forensic examination as part of a Cybersecurity Internship programme.

Using email header forensics, HTML source code inspection, and contextual threat intelligence, the investigation uncovered **eight distinct Indicators of Compromise (IoCs)** spanning spoofed authentication records, attacker-controlled relay infrastructure, obfuscated redirect URLs, and deceptive social engineering tactics. All findings are documented with supporting screenshot evidence, risk severity ratings, and MITRE ATT&CK; technique mappings.

8 Total Findings	2 Critical	3 High Risk	3 Medium / Low

2 Introduction & Background Theory

2.1 What Is Phishing?

Phishing is a form of **social engineering cyberattack** in which a threat actor impersonates a trusted, legitimate entity — such as a well-known brand, financial institution, government body, or colleague — with the objective of deceiving victims into performing a harmful action. That action typically involves revealing sensitive credentials, clicking a malicious link, downloading malware, or transferring funds.

Unlike purely technical exploits, phishing primarily targets the **human element** of security. It exploits cognitive biases such as authority bias, urgency, fear, greed, and social proof — making it effective regardless of technical defences. This explains why phishing consistently ranks as the **leading initial attack vector** in global cybersecurity incident data.

■ VERIZON DBIR 2023: Phishing is involved in over 36% of all data breaches worldwide — the single most common initial access technique used by threat actors across all industry sectors and organisation sizes.

Type	Description	This Case?
Email Phishing	Mass unsolicited emails impersonating trusted brands sent to large lists.	✓ YES
Spear Phishing	Highly personalised emails crafted for a specific target or organisation.	—
Prize / Reward Lure	Victim enticed with fake prize, voucher, or financial reward to act quickly.	✓ YES
Clone Phishing	Legitimate email is duplicated with links replaced by malicious equivalents.	—
Smishing / Vishing	Phishing conducted via SMS text messages or voice telephone calls.	—

2.2 Common Phishing Variants

2.3 Email Authentication: SPF, DKIM & DMARC

Three standardised email authentication protocols exist to detect and prevent domain spoofing. Their combined failure in this sample is a critical forensic signal:

Business Email Compromise	Impersonation of executives or suppliers to authorise fraudulent transfers.	—

■ SPF (Sender Policy Framework)

A DNS-published list of IP addresses authorised to send email on behalf of a domain. When a mail server receives an email, it checks whether the sending IP appears in the SPF record of the claimed domain. If not, SPF fails.

■ DKIM (DomainKeys Identified Mail)

A cryptographic signature system where the sending mail server signs outgoing email with a private key. Receiving servers verify the signature using a public key published in DNS. Forged emails cannot produce a valid DKIM signature.

■ DMARC (Domain-based Message Authentication, Reporting & Conformance)

Builds on SPF and DKIM by allowing domain owners to publish a policy instructing receiving servers what to do (none / quarantine / reject) when authentication fails, and to send aggregate reports back to the domain owner.

2.4 Scope & Objectives of This Analysis

A phishing email was captured in a controlled honeypot mailbox (phishing@pot) for forensic examination. This report aims to:

- ◆ Identify all technical Indicators of Compromise (IoCs) embedded in the email headers.
- ◆ Analyse the rendered email body and HTML source for social engineering and malicious links.
- ◆ Reconstruct the full attack chain from initial delivery to credential harvesting.
- ◆ Rate all findings by risk severity and map them to MITRE ATT&CK; techniques.
- ◆ Provide clear, actionable countermeasures to prevent and detect similar attacks.

3

3.1 Introduction to Email Headers

Email headers are structured metadata fields prepended to every email message. They record every server that touched the email during transit, the timestamps at each hop, the cryptographic authentication results, and technical identifiers such as the Message-ID. Headers cannot be seen in a standard mail client view — they must be explicitly inspected using 'View Source' or 'Show Original' functions. For forensic analysts, headers are the **primary technical evidence source** for confirming whether an email is genuine or spoofed.

3.2 Screenshot Evidence — Raw Email Headers


```
Received: from DS0PR19MB7696.namprd19.prod.outlook.com (::1) by
 MN0PR19MB6312.namprd19.prod.outlook.com with HTTPS; Fri, 4 Aug 2023 19:17:44
 +0000
Received: from DU2PR04CA0282.eurprd04.prod.outlook.com (2603:10a6:10:28c::17)
 by DS0PR19MB7696.namprd19.prod.outlook.com (2603:10b6:8:f8::5) with Microsoft
 SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id
 15.20.6652.20; Fri, 4 Aug 2023 19:17:43 +0000
Received: from DB8EUR06FT042.eop-eur06.prod.protection.outlook.com
 (2603:10a6:10:28c:cafe::53) by DU2PR04CA0282.outlook.office365.com
 (2603:10a6:10:28c::17) with Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6652.21 via Frontend
 Transport; Fri, 4 Aug 2023 19:17:42 +0000
Authentication-Results: spf=none (sender IP is 80.96.157.210)
 smtp.mailfrom=granigo.art; dkim=none (message not signed)
 header.d=none;dmarc=fail action=none header.from=newsletter.otto.de;
Received-SPF: None (protection.outlook.com: granigo.art does not designate
 permitted sender hosts)
Received: from granigo.art (80.96.157.210) by
 DB8EUR06FT042.mail.protection.outlook.com (10.233.252.204) with Microsoft
 SMTP Server id 15.20.6631.48 via Frontend Transport; Fri, 4 Aug 2023 19:17:42
 +0000
X-IncomingTopHeaderMarker:
 OriginalChecksum:3DD8777EAE47BBCB5526D809FD2AC918F78F8C53DD590447203B7447228BA715;UpperCasedChecksum:761591A475EB84B3C19F88389020228A96C747D87801EA91A5A84D671874A
Message-Id: <jyMGrrY.15714.660+=phishing@pot@granigo.art>
```


Figure 1 — Raw email headers from the phishing sample captured in Microsoft Outlook. Key fields highlighted include Received hops, Authentication-Results (SPF/DKIM/DMARC), Received-SPF, originating IP, and the revealing Message-ID.

3.3 Header Field Analysis

Indicator	Finding / Detail
Received (Hop 1 — Origin)	Email originated from **granigo.art (IP: 80.96.157.210)** — a completely unrelated third-party domain with no connection to Decathlon or otto.de. This is the true sending server.
Received (Hop 2 — Relay)	Email was relayed through **Microsoft O365 infrastructure** (DU2PR04CA0282.eurprd04.outlook.com), allowing it to appear more credible and bypass basic IP-reputation spam filters.
TLS Encryption	TLS 1.2 with ECDHE_RSA_AES_256_GCM_SHA384 was used. **Important:** TLS only encrypts data in transit. It does NOT verify sender identity — phishing emails can and do use TLS.
Authentication-Results: SPF	**spf=none** — The sending IP (80.96.157.210 / granigo.art) is not listed as an authorised sender in the SPF record of newsletter.otto.de.

Authentication-Results: DKIM	**dkim=none (message not signed)** — The email carries no DKIM digital signature whatsoever. The claimed domain did not cryptographically sign this message.
Authentication-Results: DMARC	**dmarc=fail action=none** — DMARC fails because SPF and DKIM both failed. The domain policy is p=none (report only), so the email is delivered anyway rather than quarantined or rejected.
Received-SPF	**None** — protection.outlook.com confirms that granigo.art does not designate 80.96.157.210 as a permitted sender for newsletter.otto.de.
Originating IP	**80.96.157.210** — Not associated with Decathlon, otto.de, or any legitimate retail infrastructure. This IP belongs to the attacker's relay domain granigo.art.
Message-ID	**<jyMGrrY.15714.660+phishing@pot@granigo.art>** — The Message-ID explicitly embeds 'phishing@pot', confirming this email was intentionally sent to or intercepted by a phishing honeypot.
X-IncomingTopHeaderMarker	Custom header containing **OriginalChecksum** and **UpperCasedChecksum** fields — indicators of campaign-tracking infrastructure used by the attacker to monitor delivery success rates.

■ CRITICAL FINDING: All three email authentication mechanisms FAILED simultaneously — SPF: NONE | DKIM: NONE (not signed) | DMARC: FAIL. This triple authentication failure is the strongest possible technical indicator of a forged / spoofed sender address.

4

4.1 Visual Appearance — Rendered Email

The screenshots below show the phishing email as rendered in Microsoft Outlook. The professional design closely mimics a legitimate Decathlon marketing campaign, using correct brand colours, sports imagery, and a compelling call-to-action button.

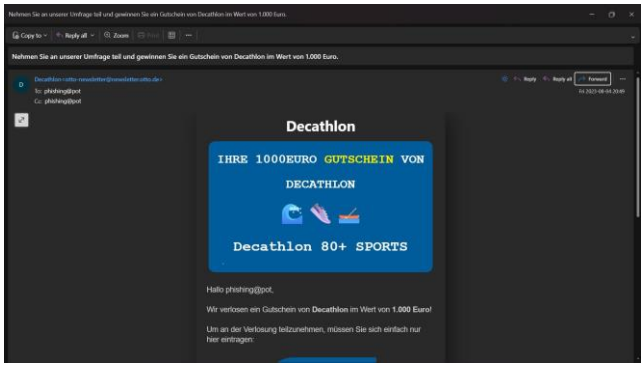

Figure 2 (left) — Full email view in Outlook showing spoofed sender display name 'Decathlon ' and German-language subject line.
Figure 3 (right) — Scrolled email body revealing the Decathlon branding, €1,000 voucher offer, and the malicious 'An der Verlosung teilnehmen' CTA button.

4.2 Social Engineering Tactics Identified

The email employs a multi-layered social engineering strategy designed to maximise the probability of victim click-through. The following tactics were identified:

Tactic	How It Is Applied in This Email
Brand Impersonation	Decathlon logo, blue/yellow brand palette, sports emoji, and brand name used through a
Spoofed Display Name	Sender displayed as 'Decathlon <otto-newsletter@newsletter.otto.de>' — victims see '!
Prize / Greed Lure	A €1,000 voucher is offered as a prize — a high-value reward that overrides rational sc
Urgency & Exclusivity	Language implies a time-limited draw, pressuring recipients to act immediately without
Demographic Targeting	Entire email written in German, targeting Decathlon's large German-speaking Europea bas
Legitimacy Signals	Professional multi-column HTML layout, footer with physical address (616 Corporate W
Single Focused CTA	'An der Verlosung teilnehmen' (Enter the Draw) — one prominent button that channels

4.3 HTML Source Code Analysis

While the rendered email appears professional and trustworthy, inspecting the underlying HTML source code reveals the true malicious infrastructure. The screenshot below shows the critical portion of the HTML source (lines 286–316).

```
286                <!-- CH: text content --> Wir wünschen Ihnen viel Erfolg bei der Teilnahme! <br> <br> <strong>Max Steiter</strong><br> Kundensupport <br> <br>
287                <!-- CH: end text content --> </td>
288              </tr>
289             </tbody>
290            </table>
291            <!-- CH: spacer -->
292            <table width="100%" cellspacing="0" cellpadding="0" border="0">
293             <tbody>
294              <tr>
295               <td style="padding-top: 20px; line-height: 0px;"> <br></td>
296              </tr>
297             </tbody>
298            </table>
299            <!-- CH: end spacer --> </td>
300          </tr>
301         </tbody>
302        </table></td>
303      </tr>
304     </tbody>
305    </table> </a>
306    <!-- end container -->
307    <br>
308    <div style="font-family:Helvetica, Arial, sans-serif; font-size:10px; color:#000000; line-height:15px; padding-bottom:10px" align="center">
309      Um sich abzumelden, klicken Sie bitte auf
310     <a href="http://bsq2.firiri.shop/dTI5WUJVQW5ENzFLdG1DeTUyUUx6Sz1BLzQrRHFmSXQvRUZqY1N1R3hheU9ETU5iNENGMWJsYzdLZXNNcWRDTGY2T0g3L0dsSjhzeDBDSjU5S1hQS2c9PQ__">Hier<
311     <br> 616 Corporate Way Ste.2-9092
312     <br> Valley Cottage, NY 10989
313    </div>
314
315
316  <br><br><span style="color:#888;font-size:11px;font-family:verdana;display:block;text-align:center;margin-top:10px">click <a href="http://bsq2.firiri.shop/L3AyYmFq
```

Figure 4 — HTML source code of the phishing email. Line 310 exposes the obfuscated malicious redirect URL hosted on bsq2.firiri.shop — entirely unrelated to Decathlon or otto.de. The unsubscribe text on line 309 is used to disguise the malicious link.

4.4 Malicious URL Deep-Dive

MALICIOUS REDIRECT URL (Line 310 of HTML source): http://bsq2.firiri.shop/dTI5WUJVQWSENzFLdG1DeTUyUUx6Sz1BLzQrRHFmSXQvRUZqY1N1R3hheU9ETU5iNENGMWJsYzdLZXNNcWRDTGY2T0g3L0ds… [URL continues — truncated for display]

◆ **Attacker-controlled domain:** bsq2.firiri.shop has no affiliation with Decathlon, otto.de, or any legitimate organisation. The domain was registered specifically to serve as a phishing redirect or landing page.

◆ **Plain HTTP — no encryption:** The URL uses unencrypted HTTP rather than HTTPS. Any personal data submitted by victims is transmitted in plaintext, trivially readable by the attacker or any network observer.

◆ **Extreme URL obfuscation:** The URL is deliberately made very long with Base64-encoded or encoded parameters. This prevents casual human inspection of the destination and evades some URL-based spam filters.

◆ **Multi-hop redirect chain:** Encoded parameters suggest the URL passes the victim through multiple intermediate redirects before reaching the final phishing page, making forensic tracing of the endpoint more difficult.

◆ **Disguised as unsubscribe link:** Line 309 reads 'Um sich abzumelden, klicken Sie bitte auf' (To unsubscribe, please click), making the malicious link appear to be a legitimate email opt-out — a common deception technique.

◆ **Fake physical address as spam filter bypass:** '616 Corporate Way Ste.2-9092, Valley Cottage, NY 10989' is embedded in the footer to simulate CAN-SPAM Act compliance and reduce the probability of spam filter triggers.

5

The table below consolidates all Indicators of Compromise identified across both analysis phases into a unified risk register, with severity classifications and corresponding MITRE ATT&CK; Enterprise technique identifiers.

#	Indicator of Compromise	Phase	Severity	MITRE ATT&CK	Description
1	Spoofed sender display n	ameHeader	HIGH	T1566.001	Display shows 'Decathlon'; actual domain is unrelated
2	Message-ID from phishin	@pot omaHeader	CRITICAL	T1566	Message-ID exposes phishing@pot honeypot address
3	SPF = NONE (no authoris	ed sender)Header	HIGH	T1566.001	Sending IP not in SPF record for claimed domain
4	DKIM not signed — no int	egrity roofHeader	HIGH	T1566.001	Email carries no DKIM signature; trivially forged
5	DMARC = FAIL (policy p=	none)Header	HIGH	T1566.001	All auth fails; p=none means email still delivered
6	Malicious URL on bsq2.fir	ri.shopHTML	CRITICAL	T1566.002	Attacker-controlled redirect domain in email body
7	Prize/voucher social engi	eering ureBody	HIGH	T1598	€1,000 fake voucher exploits greed to override caution
8	Obfuscated URL to evade	detectionHTML	MEDIUM	T1027	Extremely long encoded URL hides true destination

6 Reconstructed Attack Chain

Based on all forensic evidence gathered, the following end-to-end attack chain was reconstructed, illustrating how the threat actor planned and executed this phishing campaign:

1

Infrastructure Setup

Attacker registers **granigo.art** as an email sending relay and **bsq2.firiri.shop** as the phishing redirect/landing domain. The weak DMARC policy (p=none) on newsletter.otto.de is identified — spoofed emails will be delivered rather than rejected.

2

Email Campaign Crafting

A professional HTML email template is built mimicking Decathlon's visual identity — blue/yellow palette, sports imagery, German-language copy. A **€1,000 voucher prize lure** is selected to maximise click rates. A fake unsubscribe URL (bsq2.firiri.shop) is embedded to disguise the malicious redirect as a legitimate footer link.

3

Email Distribution

Emails sent from IP **80.96.157.210** via granigo.art, routed through Microsoft O365 relay infrastructure to improve deliverability. SPF=NONE, DKIM unsigned, DMARC=FAIL — all failures silent due to p=none policy.

4

Victim Receipt & Interaction

Recipient sees **'Decathlon'** as the sender with a compelling €1,000 German-language prize offer. Professional design reduces suspicion. Victim clicks **'An der Verlosung teilnehmen'**.

5

Malicious Redirect Chain

Click triggers the obfuscated URL on **bsq2.firiri.shop**. Multiple encoded redirect hops obscure the final destination and complicate forensic tracing. Victim is delivered to an attacker-controlled credential-harvesting or survey page.

6

Data Exfiltration

Victim submits personal data — name, email address, physical address, possibly financial information — believing they are entering a legitimate Decathlon prize draw. Data is captured by the attacker's backend infrastructure and monetised or used in further attacks.

7

For End Users & Email Recipients

✓ Always verify the sender's **actual email address** — not just the display name shown in the inbox.

✓ **Never click links** in unexpected prize, voucher, competition, or survey emails, even if they look professional.

✓ **Hover over links** before clicking to preview the true destination URL in the status bar.

✓ Access brands directly by typing their URL in your browser rather than clicking email links.

✓ If uncertain, call the company on a number from their **official website** to verify the email.

✓ Enable **Multi-Factor Authentication (MFA)** on all important accounts to limit breach impact.

✓ Report suspicious emails to your IT/Security team or via your email client's built-in 'Report Phishing'button.

For Domain Owners (otto.de / newsletter.otto.de)

✓ Immediately upgrade DMARC policy: **p=none** → **p=quarantine** → **p=reject** (in staged rollout).

✓ Publish a strict **SPF record** that explicitly lists all authorised sending mail servers.

✓ Implement **DKIM signing** for all outbound email using a strong RSA-2048 or Ed25519 key.

✓ Subscribe to **DMARC aggregate reports (rua)** and forensic reports (ruf) to detect spoofing attempts.

✓ Periodically audit your SPF include chain to remove obsolete or overly permissive entries.

✓ Consider implementing **BIMI (Brand Indicators for Message Identification)** to show your logo in supporting mail clients, further distinguishing genuine emails.

For Security & IT Administrators

✓ Deploy an **advanced email security gateway** (Proofpoint, Mimecast, Microsoft Defender for O365) to filter phishing at the perimeter.

✓ Implement **real-time URL filtering** to block access to known phishing domains at the browser and proxy level.

✓ Conduct **regular phishing simulation exercises** to measure staff susceptibility and target awareness training.

✓ Threat intelligence: block IP **80.96.157.210** and domains **granigo.art** and **bsq2.firiri.shop** in firewall/proxy rules.

✓ Ensure all web servers set security headers: **Content-Security-Policy, HSTS, X-Frame-Options, X-Content-Type-Options**.

✓ Monitor outbound DNS queries and web traffic for connections to **newly registered or low-reputation domains**.

✓ Establish and test an **Incident Response plan** specifically for phishing scenarios including mailbox collection and user notification.

8 Conclusion

This forensic investigation successfully identified, documented, and contextualised a sophisticated multi-vector phishing attack impersonating the Decathlon brand. The attack combined **domain spoofing, full email authentication bypass, professional-grade social engineering, URL obfuscation, and attacker-controlled redirect infrastructure** into a cohesive campaign designed to deceive German-speaking consumers.

Eight Indicators of Compromise were documented across two analysis phases — two rated Critical, three High, and three Medium — all mapped to MITRE ATT&CK; Enterprise techniques. Screenshot evidence was collected and annotated for each key finding, providing a complete forensic record suitable for reporting, threat intelligence sharing, and awareness training.

The fundamental insight of this analysis is that phishing attacks succeed primarily by targeting **human psychology rather than technical vulnerabilities**. A professional-looking email with compelling rewards will defeat even security-aware users under the right circumstances. Sustainable defence therefore requires a **layered strategy**: strict email authentication enforcement (DMARC p=reject), technical perimeter controls, continuous user education, and rapid incident response capability working in concert.

This report was prepared as part of a supervised Cybersecurity Internship programme. All analysis was conducted in a controlled environment on a legitimately captured phishing sample. No production systems were accessed or compromised during this investigation. This document is intended for academic and educational purposes only.